

Unsupervised Learning

CompTIA SecAI+ | Section 4: Model Training Techniques

The Unsupervised Learning Paradigm

Unsupervised learning discovers structure in data without labels. No human expert tells the algorithm what correct looks like — the algorithm identifies natural groupings, outliers, and low-dimensional representations entirely from the data's internal structure. This fundamentally different learning signal makes unsupervised learning complementary to, rather than a replacement for, supervised learning.

In cybersecurity, unsupervised learning addresses a structural limitation of supervised learning: you can only label what you already know is malicious. Unknown threats — zero-day exploits, novel ransomware families, first-seen attacker infrastructure — have no labels because no analyst has ever seen them. Unsupervised learning can surface these unknowns by detecting that they differ from everything else, even without knowing what they are.

Core Distinction: Supervised learning optimises for a specific labelled task. Unsupervised learning finds structure that may or may not be security-relevant — human interpretation is always required to determine whether discovered patterns represent threats.

Why Unsupervised Learning Is Critical in Security

Security Challenge	How Unsupervised Learning Addresses It
Label scarcity	Works without any labels — immediate value from day one of deployment
Unknown threats	Detects novelty relative to learned normal behaviour, not known signatures
Attacker evolution	Normal-based detection does not require updating when attackers change tactics
Cold start	Useful before any labelled data is accumulated
Scale	Analyses millions of events automatically, surfacing the subset worth human investigation
Insider threat	Builds individual behavioural baselines; detects deviation without predefined rules

Clustering: Finding Natural Groupings

Clustering algorithms partition data points into groups such that points within a group are more similar to each other than to points in other groups. The key characteristic is natural — the algorithm discovers groupings that exist in the data, rather than being told which groupings to look for.

Similarity is measured by distance in the feature space. Common metrics include Euclidean distance (geometric distance between feature vectors), cosine similarity (angle between vectors, useful when

magnitude matters less than direction), and Hamming distance (for binary features such as presence or absence of API calls).

K-Means Clustering

K-means partitions n data points into exactly k clusters by iteratively minimising within-cluster variance. The algorithm requires k to be specified in advance — a significant limitation when you do not know how many natural groups exist in your data.

Step	Operation	Security Context
1. Initialise	Place k random centroid points in feature space	Random initialisation can produce different results — use multiple runs
2. Assign	Each data point joins the nearest centroid's cluster	Network connections group into proto-clusters by behavioural similarity
3. Update	Move each centroid to the mean of its assigned points	Centroids shift to represent the average of each behaviour type
4. Repeat	Alternate steps 2 and 3 until assignments stop changing	Convergence typically in tens to hundreds of iterations
5. Evaluate	Measure inertia (within-cluster sum of squares)	Elbow method plots inertia vs. k to choose the optimal k

In network security, k-means applied to network flow features commonly produces clusters corresponding to web browsing, database queries, file transfers, streaming, and administrative traffic. Flows that do not fit cleanly into any cluster warrant investigation as potential attacks.

Hierarchical Clustering

Hierarchical clustering does not require specifying the number of clusters in advance. Agglomerative (bottom-up) hierarchical clustering starts with each data point as its own cluster and repeatedly merges the two most similar clusters until all points belong to one cluster. The result is a dendrogram — a tree diagram showing the complete merge history.

The dendrogram can be cut at different heights to produce different numbers of clusters. This is particularly valuable in threat intelligence, where the number of distinct malware families is not known in advance. Cutting the dendrogram at various heights reveals the hierarchical structure of the malware landscape: major families split into subfamilies, which split into specific campaigns or variants.

- Linkage criteria define how cluster similarity is measured: single (minimum distance), complete (maximum distance), Ward (minimises within-cluster variance)
- Ward linkage generally produces the most balanced, compact clusters and is a common default
- Computationally expensive — limits application to datasets of hundreds of thousands of points at most
- HDBSCAN is a hierarchical alternative that scales better and handles variable-density clusters

Anomaly Detection: The Primary Security Application

Anomaly detection learns a model of normal behaviour and flags data points that deviate significantly from that model. It is the most direct application of unsupervised learning to security: attacks are, by definition, abnormal. You do not need labelled attack examples — you only need enough normal data to characterise what normal looks like.

Method	How It Models Normal	Security Strength	Limitation
Statistical threshold	Mean plus or minus k standard deviations per feature	Simple, interpretable, fast	Assumes Gaussian distribution; misses multivariate anomalies
Isolation Forest	Random recursive partitioning; anomalies isolated quickly	Fast; handles high-dimensional data; no distribution assumption	Requires tuning contamination fraction; may miss clustered anomalies
Autoencoder	Neural network trained to reconstruct normal inputs	Captures complex non-linear patterns; high reconstruction error signals anomaly	Requires substantial normal data; neural inference latency
OCSVM	SVM trained on normal data; anomalies fall outside the boundary	Effective in high-dimensional spaces	Slow to train at scale; sensitive to hyperparameter choice

Real-World Incident — Darktrace Casino Breach Detection (2017): Darktrace's unsupervised learning engine detected an advanced persistent threat inside a US casino's network that entered through a connected fish tank thermostat. The unsupervised model identified the thermostat's network behaviour as anomalous relative to its learned baseline — unusual external IP, unusual times, unusual volumes. No signature existed for this attack because the entry vector was novel. This is the canonical example of unsupervised detection of an unknown threat.

Isolation Forest: Deep Dive

Isolation Forest exploits the geometric insight that anomalies are rare and different from the majority of points, making them easier to isolate. The algorithm builds an ensemble of random isolation trees.

Each tree recursively partitions the data by randomly selecting a feature and a random split point. Normal points require many splits to isolate because they are surrounded by many similar points. Anomalous points are isolated in the first few splits because they are far from other points. The anomaly score is the average depth at which a point is isolated — lower depth equals higher anomaly score.

- Linear time complexity $O(n)$ — scales well to millions of network flows
- No assumption about data distribution — works on complex, non-Gaussian security data
- Handles high dimensionality without dimensionality reduction
- The contamination hyperparameter sets the expected fraction of anomalies (typically 0.01-0.05%)
- Effective for point anomalies; less effective for contextual anomalies (normal value in abnormal context)

Autoencoders for Anomaly Detection

An autoencoder is a neural network trained to reconstruct its own input. It consists of an encoder (compresses input to a low-dimensional latent representation) and a decoder (reconstructs input from the latent representation). Training minimises reconstruction error on normal data.

After training, anomalous inputs produce high reconstruction error because the encoder-decoder pair learned only normal patterns. High reconstruction error becomes the anomaly signal, and a threshold determined on validation data governs what is flagged.

Component	Role	Security Analogy
Encoder	Compresses input to latent representation	Extracts the fingerprint of normal behaviour
Latent space	Low-dimensional representation of normal patterns	The model's internal understanding of what normal looks like
Decoder	Reconstructs input from latent representation	Attempts to recreate the original from the fingerprint
Reconstruction error	Difference between input and reconstruction	High error means the pattern is unlike anything normal the model learned

Dimensionality Reduction in Security

Security datasets routinely have hundreds or thousands of features. Dimensionality reduction projects data into a lower-dimensional space while preserving important structure. This serves visualisation, noise removal, and downstream model efficiency.

Technique	Mechanism	Security Use Case
PCA	Linear projection onto axes of maximum variance	Compressing log features; identifying dominant network behaviour patterns
t-SNE	Non-linear projection preserving local neighbourhood structure	2D visualisation of malware families; revealing cluster separation
UMAP	Non-linear projection preserving both local and global structure; faster than t-SNE	Interactive security dashboards; large-scale threat intelligence visualisation
Autoencoder (encoder only)	Non-linear compression via neural network	Learning compact normal behaviour representations for anomaly detection

Practical Security Applications

Network traffic clustering extracts features from flows (bytes, packets, duration, ports, protocols, timing) and clusters them. Natural clusters correspond to application types and user behaviours. Flows in small

clusters or that do not fit any cluster are prioritised for investigation. This continuously maps the network's behavioural landscape without requiring labels.

User and Entity Behaviour Analytics (UEBA) builds individual baselines for each user by analysing their historical activity patterns. Activity that deviates from the user's own cluster — accessing files outside normal hours, logging in from unusual locations, transferring large volumes externally — triggers an alert. Each user has their own baseline, so UEBA catches privilege misuse even for technically permitted actions.

Malware family discovery clusters malware samples by behavioural features (API calls, file operations, network behaviour, registry modifications). Clusters correspond to families sharing implementation characteristics. New samples in isolated clusters represent potentially undocumented families that deserve prioritised analysis.

Combining Supervised and Unsupervised Learning

Pattern	How It Works	Example
Detect-then-classify	Unsupervised anomaly detection surfaces candidates; supervised classifier categorises them	Isolation Forest flags anomalous flows; random forest classifies as scan, exfiltration, or lateral movement
Cluster-then-label	Clustering identifies natural groupings; analysts label representative examples; supervised model trained on labels	K-means clusters malware samples; analysts label one sample per cluster; labelled dataset trains a supervised classifier
Transfer-then-fine-tune	Unsupervised representations used as features for supervised model	Autoencoder latent vectors used as features for insider threat classifier
Ensemble	Multiple models vote or combine scores	Signature match + anomaly score + supervised probability combined into a risk score

Limitations and the Human Partnership

Unsupervised learning surfaces patterns, but it cannot determine whether those patterns are security-relevant. Clustering groups similar things — but similar is defined geometrically in feature space, not semantically. A cluster may represent a threat, a new application, a misconfigured device, or simply a group of users who work the same hours.

- Anomalies are not attacks — they are statistical outliers; most anomalies in practice are legitimate unusual events
- Cluster quality depends on feature quality — poor feature engineering produces meaningless clusters
- Unsupervised models require calibration: contamination rate or anomaly threshold must be tuned to operational capacity
- Human analysts must review and interpret all flagged events — unsupervised learning scales human attention, it does not replace human judgment

- False positive management is critical: if each alert requires 30 minutes of investigation and 200 alerts fire daily, the system is operationally unsustainable regardless of detection capability

Key Terms Glossary

Term	Definition
Unsupervised learning	ML paradigm that finds structure in unlabelled data; no correct output is specified
Clustering	Grouping data points by similarity without predefined categories
K-means	Clustering algorithm that partitions data into exactly k clusters by minimising within-cluster variance
Hierarchical clustering	Builds a tree of clusters (dendrogram) by iteratively merging the most similar clusters
Dendrogram	Tree diagram showing the complete merge history from hierarchical clustering
Anomaly detection	Identifying data points that deviate significantly from the learned model of normal behaviour
Isolation Forest	Anomaly detection algorithm that identifies anomalies as points isolated quickly by random recursive partitioning
Autoencoder	Neural network trained to reconstruct its input; high reconstruction error signals anomalies
Reconstruction error	Difference between an autoencoder's input and its output; the anomaly signal
PCA	Principal Component Analysis; linear dimensionality reduction onto axes of maximum variance
t-SNE	Non-linear dimensionality reduction preserving local structure; used for visualisation
UEBA	User and Entity Behaviour Analytics; builds individual baselines; flags deviations indicating insider threat or compromise
Concept drift (unsupervised)	Normal behaviour changes over time, causing anomaly detection models to generate false positives on new legitimate behaviour
Cold start advantage	Unsupervised learning provides security value from day one without requiring labelled examples

Quick Revision Checklist

- Define unsupervised learning and explain why it is uniquely valuable for detecting unknown security threats
- Describe the four steps of k-means and its requirement to specify k in advance
- Explain hierarchical clustering and how a dendrogram enables flexible cluster selection
- Define anomaly detection and explain why it does not require labelled attack examples
- Describe how Isolation Forest identifies anomalies through random recursive partitioning
- Explain autoencoders and how reconstruction error serves as an anomaly signal

- Describe three practical unsupervised security applications: network clustering, UEBA, malware family discovery
- Explain two dimensionality reduction techniques and their security use cases
- Describe two patterns for combining supervised and unsupervised learning in production systems
- List three limitations of unsupervised learning that require human analyst involvement

20 Exam-Based MCQs — Unsupervised Learning

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Why is unsupervised learning particularly suited to detecting zero-day exploits?

- A. It trains faster than supervised learning
- B. It does not require labelled attack examples — it detects events that deviate from learned normal behaviour regardless of whether the attack has been seen before
- C. It produces more accurate classifiers than supervised models
- D. It requires less data than supervised learning

Answer: B **Explanation:** Zero-day exploits have no labels (B). Unsupervised anomaly detection works by identifying what is different from normal — a zero-day attack behaving unusually will be flagged even without prior knowledge of its existence. Training speed (A) is irrelevant. Accuracy comparisons (C) are task-specific; supervised learning generally outperforms when labels are available. Unsupervised learning often benefits from more data, not less (D).

Q2. A security analyst applies k-means with k=5 to network flows and discovers one cluster contains 98% of all flows while four clusters contain fewer than 10 flows each. What does this most likely indicate?

- A. The model is overfitting
- B. K=5 is too large — most flows are similar and there are few natural clusters in this dataset
- C. The four small clusters are confirmed attack groups and should be immediately blocked
- D. The clustering algorithm failed and should be rerun

Answer: B **Explanation:** When one cluster dominates, it indicates the data has fewer natural groupings than the specified k (B). The four small clusters may represent anomalies worth investigating, but they are not automatically confirmed attacks (C). Overfitting (A) is a supervised learning concept. The algorithm ran and produced results — failure would mean no output (D).

Q3. What is the primary security advantage of hierarchical clustering over k-means for malware family discovery?

- A. Hierarchical clustering is faster for large datasets
- B. Hierarchical clustering does not require specifying the number of families in advance and reveals the hierarchical relationship between variants

- C. Hierarchical clustering uses supervised labels to improve cluster quality
- D. Hierarchical clustering prevents false positives

Answer: B **Explanation:** The number of malware families is unknown in advance — hierarchical clustering (B) does not require pre-specifying k and produces a dendrogram showing how families relate to each other. K-means requires k. Hierarchical clustering is more computationally expensive (A is wrong). It is unsupervised (C is wrong). It does not directly prevent false positives (D).

Q4. Scenario: A mid-sized e-commerce company deploys an Isolation Forest on network traffic. The team has 3 analysts across two shifts. The model generates 500 anomaly alerts per shift, of which 490 are legitimate unusual events. An Isolation Forest generates 500 anomaly alerts per shift, but 490 are legitimate unusual events (configuration changes, updates, backups). What is the correct adjustment?

- A. Increase the contamination hyperparameter to accept more anomalies
- B. Decrease the contamination hyperparameter or raise the anomaly score threshold to reduce false positive volume
- C. Replace the Isolation Forest with a supervised classifier
- D. Add more normal training data

Answer: B **Explanation:** The contamination parameter sets the expected fraction of anomalies (B). If it is too high, the model flags too many events as anomalous. Lowering it or raising the score threshold reduces alert volume. Increasing contamination (A) would generate even more alerts. Replacing with a supervised model (C) requires labelled data and does not address the immediate problem. More normal training data (D) may help calibration but the immediate fix is threshold adjustment.

Q5. A UEBA system flags a database administrator accessing thousands of records at 2 AM Saturday. Investigation confirms they were running a scheduled maintenance query. What does this demonstrate?

- A. The UEBA model is broken and should be replaced
- B. Anomalies detected by unsupervised learning require human investigation to determine security relevance — not all anomalies are attacks
- C. UEBA should not monitor administrator accounts
- D. The model should be retrained to never flag this administrator again

Answer: B **Explanation:** Statistical anomalies are not automatically security incidents (B). The DBA's action was unusual relative to their baseline but had a legitimate explanation. This is the correct workflow — unsupervised learning flags, humans assess. The model is working correctly (A is wrong). All privileged accounts should be monitored (C is wrong). Retraining to suppress this specific behaviour (D) might cause the model to miss genuine insider threats using the same time-of-day pattern.

Q6. Scenario: A company deployed an autoencoder for DNS traffic anomaly detection. Six months after deployment, they add a new internal DNS resolver and the model begins generating 300% more alerts.

An autoencoder trained on one month of normal DNS traffic begins generating 300% more alerts six months later after a new internal DNS resolver is added. What is the most likely cause?

- A. The autoencoder was not trained on enough data
- B. DNS exfiltration attempts have increased significantly
- C. The new DNS resolver's traffic patterns differ from the training distribution, causing concept drift — the model treats new legitimate behaviour as anomalous
- D. The autoencoder's reconstruction error threshold is too low

Answer: C **Explanation:** Adding a new DNS resolver changes the distribution of normal DNS traffic (C). The autoencoder trained on the old distribution treats the new resolver's traffic as anomalous. This is concept drift. Training data volume (A) is not the immediate cause. Attack increase (B) would not explain a 300% sustained increase immediately after an infrastructure change. Lowering the threshold (D) might reduce alerts short-term but the model needs retraining.

Q7. Which statement best describes the complementary roles of PCA and t-SNE in security analysis?

- A. t-SNE should be used for model training; PCA for visualisation only
- B. PCA is a linear technique suited to identifying dominant variance directions; t-SNE is non-linear and better preserves local cluster structure for visualisation
- C. PCA requires labelled data; t-SNE does not
- D. t-SNE produces directly interpretable dimensions; PCA does not

Answer: B **Explanation:** PCA (B) finds the axes of maximum linear variance — useful for compression and identifying dominant patterns. t-SNE preserves local neighbourhood structure non-linearly, making it excellent for visualising cluster separation. Neither technique requires labels (C is wrong). t-SNE axes are not directly interpretable; PCA components are mathematical combinations of original features (D is wrong). Both can be used in model pipelines (A is wrong).

Q8. A threat intelligence team clusters 10,000 malware samples and discovers 23 clusters, of which 8 do not match any known family. What is the most appropriate next step?

- A. Discard the eight unknown clusters as likely false positives
- B. Prioritise the eight unknown clusters for manual analysis — they may represent previously undocumented malware families
- C. Retrain the clustering with $k=15$ to match only known families
- D. Submit the eight clusters to a public malware database immediately

Answer: B **Explanation:** Unknown clusters (B) in malware analysis are potential discoveries — new families or variants not yet documented. These deserve prioritised manual analysis. Discarding them (A) would cause the team to miss novel threats. Forcing $k=15$ (C) would merge or hide the unknown patterns. Immediate public submission (D) is premature without analysis and may violate data handling policies.

Q9. What is the cold start advantage of unsupervised learning in security?

- A. Unsupervised models train faster than supervised models

- B. Unsupervised learning requires no labelled data, so it provides security value immediately when deployed in a new environment where no historical labelled incidents exist
- C. Unsupervised models do not require computational resources during initial deployment
- D. Unsupervised learning eliminates the need for any human security analysts

Answer: B **Explanation:** The cold start advantage (B) is that unsupervised learning works from day one in a new environment. Supervised learning cannot operate until labelled data is accumulated, creating a security gap. Training speed (A) varies by algorithm. Computational resources are always required (C). Unsupervised learning augments but does not replace human analysts (D).

Q10. What is the advantage of a detect-then-classify pipeline combining Isolation Forest with a supervised random forest over using either model alone?

- A. It eliminates false positives entirely
- B. Isolation Forest surfaces unusual events without labels; the random forest classifies them into specific attack types with higher precision than anomaly score alone
- C. The combination reduces computational overhead
- D. Using two models always outperforms using one

Answer: B **Explanation:** The hybrid architecture (B) leverages complementary strengths: Isolation Forest flags anomalies without labels, solving the cold start problem for novel threats. The random forest then classifies flagged events into specific, operationally meaningful categories with the precision that comes from supervised training. No architecture eliminates false positives entirely (A). Two models increase computational overhead (C). Combining models does not automatically improve performance if redundant (D).

Q11. Why is reconstruction error an effective anomaly signal in autoencoder-based security systems?

- A. Lower reconstruction error indicates higher anomaly probability
- B. Reconstruction error is 0 for all normal inputs and 1 for all anomalies
- C. The autoencoder was trained only on normal data; anomalous inputs do not match learned patterns and are poorly reconstructed, yielding higher error
- D. Reconstruction error measures the difference between two autoencoders' outputs

Answer: C **Explanation:** An autoencoder trained exclusively on normal data (C) learns to encode and decode normal patterns efficiently. Anomalous inputs produce high reconstruction error because the model has never learned their patterns. Higher error = larger divergence from learned normality = anomaly. Higher anomaly probability corresponds to higher error, not lower (A). Reconstruction error is continuous, not binary (B). It compares input to the same model's output (D).

Q12. A security team reduces 800 network flow features to 20 principal components before anomaly detection. What is the primary benefit?

- A. PCA labels the components with meaningful security names
- B. PCA eliminates all noise from the dataset

- C. Reducing dimensionality removes redundant correlated features and reduces the curse of dimensionality, improving performance and efficiency
- D. PCA guarantees the top 20 components capture all security-relevant patterns

Answer: C **Explanation:** PCA reduces correlated and redundant features into orthogonal principal components, addressing the curse of dimensionality (C) where high-dimensional spaces make distance measurements unreliable. PCA produces components labelled PC1, PC2, etc. — not meaningful security names (A). PCA redistributes variance but does not eliminate noise (B). The top components capture maximum variance but may not capture all security-relevant patterns, especially rare attacks with low variance (D).

Q13. An Isolation Forest with contamination=0.01 is deployed on Monday. On Friday, a large-scale software patch deployment causes 15% of endpoints to behave differently for several hours. What is the expected behaviour?

- A. The model will not flag patch-related traffic because patching is legitimate activity
- B. The model will flag approximately 1% of events as usual
- C. The model may generate a large volume of false positive anomaly alerts because patch deployment creates widespread unusual behaviour exceeding the contamination assumption
- D. The model will automatically adapt its threshold to accommodate the deployment

Answer: C **Explanation:** The contamination parameter expects 1% anomalies. When 15% of endpoints behave unusually, the actual fraction of unusual events far exceeds the model's assumption (C). Legitimate activity is not automatically excluded (A). The model flags based on score threshold, not exactly 1% per day (B). Isolation Forest does not dynamically adapt its threshold (D).

Q14. Which distance metric would be most appropriate for clustering binary-feature malware samples where each feature indicates presence or absence of a specific API call?

- A. Euclidean distance
- B. Hamming distance
- C. Cosine similarity
- D. Manhattan distance

Answer: B **Explanation:** Hamming distance (B) measures the number of positions where two binary strings differ — exactly appropriate for binary feature vectors (API present/absent). Euclidean distance (A) treats binary features as continuous values and over-weights certain positions. Cosine similarity (C) measures angle, losing the present/absent interpretation for binary features. Manhattan distance (D) is appropriate for continuous features.

Q15. A data scientist argues unsupervised learning should replace supervised learning in the SOC because it requires no labelled data. What is the most important counterargument?

- A. Unsupervised learning is computationally more expensive

- B. Unsupervised learning finds patterns but cannot optimise for specific security outcomes — it may surface statistically interesting patterns that are not security-relevant, and lacks the precision of supervised models trained on confirmed attacks
- C. Unsupervised learning only works for clustering, not anomaly detection
- D. Supervised learning requires no maintenance after deployment

Answer: B **Explanation:** The strongest counterargument (B) is that unsupervised learning has no objective function aligned with security goals — it finds patterns, not necessarily threats. Supervised learning directly optimises for the security task. The two approaches are complementary, not substitutes. Computational cost (A) varies by algorithm. Unsupervised learning includes anomaly detection, dimensionality reduction, and more (C is wrong). Supervised models require continuous retraining (D is wrong).

Q16. Scenario: A hospital's UEBA system monitors clinical staff access to electronic health records. A nurse is flagged for accessing 500 patient records in one shift (3-month average: 30). Investigation reveals three other nurses called in sick and she covered their patient loads. A UEBA system flags a nurse for accessing 500 patient records in one day (baseline: 30) because she was covering for three sick colleagues. What should the UEBA implementation include to handle legitimate coverage scenarios?

- A. Exclude nurses from UEBA monitoring
- B. Increase the anomaly threshold for all users to prevent similar alerts
- C. A workflow to cross-reference anomaly flags with HR scheduling data or a supervisory pre-authorisation mechanism for coverage
- D. Remove the record access feature from the model

Answer: C **Explanation:** Context enrichment (C) — cross-referencing with HR scheduling or requiring supervisory pre-authorisation for coverage — reduces false positives without compromising security. Excluding nurses (A) creates a monitoring blind spot. Increasing the global threshold (B) would reduce sensitivity for all users, potentially hiding real insider threats. Removing the record access feature (D) eliminates a highly relevant signal for healthcare insider threat detection.

Q17. What distinguishes UEBA from a traditional rule-based insider threat detection system?

- A. UEBA requires a signature database of known malicious actions
- B. UEBA builds individual per-user baselines and detects deviation from each user's own normal behaviour; rule-based systems apply the same rules to all users regardless of individual context
- C. UEBA can only detect data exfiltration
- D. UEBA requires no human review of flagged events

Answer: B **Explanation:** UEBA's defining advantage (B) is personalised baselines: a user who normally downloads 50 MB per day flagged at 5 GB, while a data engineer who routinely downloads 5 GB is not. Rule-based systems apply the same threshold to everyone. UEBA does not use signatures (A). UEBA detects multiple threat types (C is wrong). UEBA still requires human review (D).

Q18. Two samples placed in the same cluster by a malware clustering exercise — what does this imply?

- A. Both samples are from the same malware family with certainty
- B. The samples have similar feature vectors, suggesting possible shared code or origin — but this must be validated by analyst review
- C. Neither sample is malicious
- D. The clustering algorithm made an error

Answer: B **Explanation:** Clustering groups samples by feature similarity (B). Samples in the same cluster share patterns in the feature space, which may reflect shared code, C2 infrastructure, authors, or tooling. This is a statistical observation requiring analyst validation. Cluster membership does not guarantee the same family (A). Both samples in an anomalous cluster does not indicate benignness (C). The assignment is not an error (D).

Q19. Which technique best helps a security analyst visually understand whether 50,000 network flow records contain distinct behavioural clusters?

- A. PCA — reduce to 2 components and plot
- B. t-SNE — reduce to 2 dimensions for visualisation
- C. Isolation Forest — plot anomaly scores
- D. K-means with k=2

Answer: B **Explanation:** t-SNE (B) is the preferred visualisation technique for discovering cluster structure because it preserves local neighbourhood relationships non-linearly, making distinct clusters visually separate even when non-linearly separated in the original space. PCA (A) is linear and may not reveal non-linearly separated clusters. Isolation Forest anomaly scores (C) provide a 1D ranking, not a 2D visualisation of cluster structure. K-means (D) requires specifying k and imposes structure rather than revealing natural structure.

Q20. *Scenario:* A financial institution has 50,000 normal user-day records and only 30 confirmed insider threat incidents. A security ML engineer proposes training an autoencoder on the 50,000 normal records to produce a 64-dimensional latent representation, then using those representations as features for a supervised random forest classifier using the 30 confirmed incidents as positive examples. An autoencoder trained on normal user behaviour is proposed as the feature extractor for a supervised insider threat classifier. What design pattern does this represent?

- A. Cluster-then-label; it eliminates the need for any labelled data
- B. Transfer-then-fine-tune; the autoencoder learns compact generalisable normal behaviour representations that the supervised classifier uses as informative features, reducing the labelled data needed
- C. Detect-then-classify; the autoencoder detects anomalies and the classifier labels them
- D. Ensemble; the two models vote on the final prediction

Answer: B **Explanation:** Using the autoencoder's latent representation as features for a supervised model (B) is the transfer-then-fine-tune pattern: the autoencoder's unsupervised training on abundant

normal data produces rich, compact representations. The supervised classifier then learns to distinguish insider threats using these informative features, requiring fewer labelled examples. The supervised classifier still needs labels (A is wrong — this is not cluster-then-label). The autoencoder serves as feature extractor, not anomaly detector (C is wrong). The models are not voting (D is wrong).